

SCENARIO 3 — LLM-INTEGRATED ACCOUNT RECOVERY AND PROFILE MANAGEMENT SYSTEM

System Overview

The system is a web-based account recovery and profile management application enhanced with an AI assistant. The system allows users to initiate account recovery, submit recovery and verification information, validate recovery credentials or recovery tokens, and update authorized profile information.

The AI assistant provides account-related support and guidance to the user. The AI assistant is not an authentication authority, does not independently verify user identity, does not generate or validate authoritative recovery tokens, and does not directly modify user accounts.

The authoritative recovery and identity-verification decisions are performed by the Account Recovery Service. The Profile Management Service performs profile modifications only after the recovery/authentication state has been successfully established.

The external LLM provider is a third-party service outside the application's security control.

TRUST MODEL

Zone A — External User Environment

Contains the End User and represents the untrusted user-controlled environment.

Zone B — Application Environment

Contains:

- P1 Web Frontend Interface
- P2 Account Recovery Service
- P3 Profile Management Service
- P4 AI Account Support Assistant
- P5 LLM Integration Service

Zone C — Data Layer

Contains:

- DS1 User Database
- DS2 Recovery Token Storage

Zone D — External LLM Provider

Contains:

- EE2 External LLM Provider

The external LLM provider is outside the application's security control and must not directly access the application's databases or internal services.

SECURITY AUTHORITIES

P2 Account Recovery Service is the authoritative component for:

- recovery request processing
- identity/verification checks
- recovery-state creation
- recovery-token generation
- recovery-token validation
- recovery-token expiration and invalidation
- determining whether a recovery operation is authorized

DS1 User Database is the authoritative source for:

- account identity
- profile information
- account status

- recovery-related verification information

DS2 Recovery Token Storage is the authoritative storage for:

- active recovery tokens
- token metadata
- token expiration
- token state
- token consumption/invalidation status

P3 Profile Management Service performs profile updates only after receiving an authorized profile-update request from P2.

P4 AI Account Support Assistant provides conversational account-related assistance but does not make authentication or authorization decisions.

P5 LLM Integration Service is the only component that communicates with the external LLM provider.

The external LLM must never directly access DS1, DS2, P2, or P3.

RECOVERY WORKFLOW

1. The End User initiates an account recovery request through P1.
2. P1 forwards the recovery request details to P2.
3. P2 retrieves the necessary account and verification information from DS1.
4. DS1 returns the relevant verification result/data to P2.
5. P2 performs the authoritative recovery/identity verification decision.
6. If the recovery request is authorized, P2 generates a recovery token or recovery state.
7. P2 stores the recovery token and associated security metadata in DS2.
8. DS2 confirms successful token storage.
9. P2 returns the appropriate recovery result or recovery challenge to P1.
10. The End User submits the recovery token or verification response through P1.
11. P1 forwards the submitted recovery credential/token to P2.
12. P2 requests token validation from DS2.
13. DS2 returns the token validation result.
14. P2 verifies token validity, expiration, ownership, intended purpose, and current state.
15. A valid recovery token is consumed or invalidated so that it cannot be reused.
16. Only after successful recovery validation does P2 authorize profile modification.

PROFILE MANAGEMENT WORKFLOW

17. P2 sends an authorized profile-update request to P3.
18. The request must contain only the profile changes that the recovered/authorized user is permitted to make.

19. P3 performs the requested profile modification against DS1.

20. DS1 returns the update result.

21. P3 returns the profile-update result to P2/P1 as appropriate.

22. P1 presents the result to the user.

AI ACCOUNT SUPPORT WORKFLOW

The user may ask the AI Account Support Assistant account-related questions.

The user question is sent from P1 to P4.

P4 does not independently authenticate the user or determine whether the user is authorized to perform an account operation.

Where account-specific context is required, P4 obtains only approved contextual information from the application's authorized services.

The AI assistant must not receive raw recovery tokens, passwords, password-reset secrets, or unnecessary sensitive authentication material.

P4 sends the user question together with approved contextual information to P5.

P5 sends the approved prompt/context to the external LLM provider.

The external LLM generates a response.

P5 returns the generated response to P4.

P4 returns the processed AI response to P1.

P1 displays the response to the user.

The generated LLM response is untrusted output and must not directly trigger account recovery, profile modification, token creation, authorization, or authentication decisions.

SECURITY REQUIREMENTS

The threat model must explicitly consider:

- account takeover
- recovery-token theft
- recovery-token replay
- recovery-token prediction
- recovery-token fixation
- recovery-token leakage
- token expiration failure
- failure to invalidate consumed tokens
- brute-force recovery attempts
- recovery-request enumeration
- identity-verification bypass
- unauthorized profile modification
- privilege escalation
- manipulation of recovery state
- unauthorized access to user profile information
- sensitive information disclosure
- prompt injection

- indirect prompt injection
- malicious user-provided account information
- leakage of sensitive recovery information to the LLM
- excessive trust in LLM-generated responses
- LLM output manipulation
- unauthorized AI-assisted actions
- session/account-context confusion
- insecure authorization decisions
- denial of service
- database tampering
- token-storage compromise
- insufficient auditability
- data leakage across trust boundaries

The threat model must distinguish between threats caused by the conventional account-recovery architecture and threats introduced or amplified by the LLM integration.

The LLM must be treated as an untrusted external processing component rather than an authentication or authorization authority.